TRIMARC SECURITY




TRIMARC
WEBCAST
WILL BEGIN SHORTLY

Upcoming Trimarc Webcasts



Securing Active Directory: Protecting AD Administration
Wednesday, July 15, 2020
1pm to 2pm (Eastern)
Presenter: Sean Metcalf

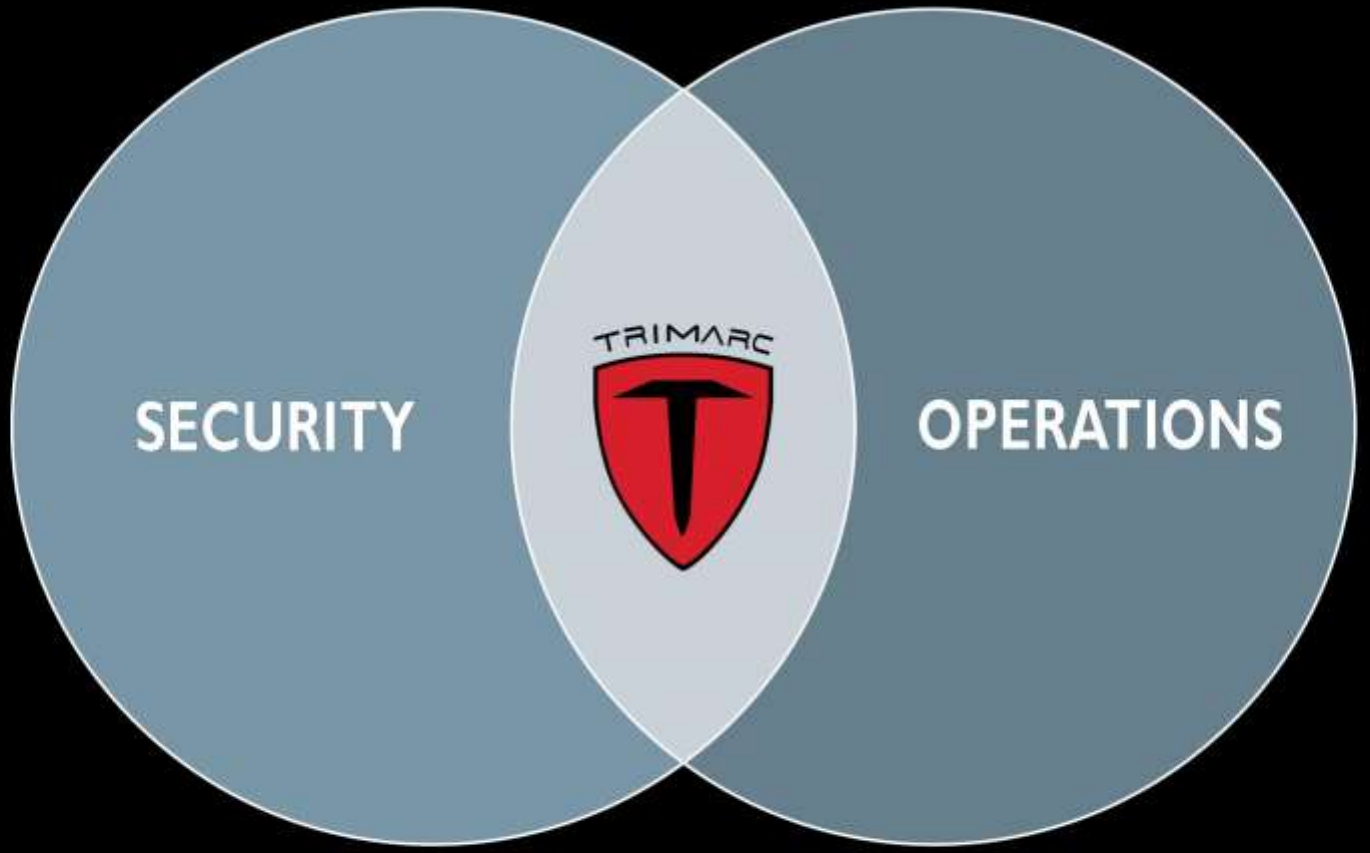
Registration: Trimarc.co/SecurityWebcasts

Trimarc is your Trusted Advisor For Securing your Enterprise



Trimarc's Active Directory Security Assessment provides actionable information enabling you to quickly resolve critical issues.

Trimarc Expertise



Trimarc Combines Operational Knowledge & Experience with Security Vision

Trimarc Security Assessments

- Comprehensive review
- Detailed, actionable recommendations
- Provides a roadmap to improve security posture
- Trimarc Security Assessments:
  - Active Directory
    - Active Directory Security Assessment (ADSA)
  - Microsoft Office 365 & Azure AD
    - Microsoft Cloud Security Assessment (MCSA)
  - VMware
    - VMware Infrastructure Security Assessment (VISA)

Active Directory Security Assessment (ADSA)

- Comprehensive AD security posture assessment
- Effectively a sophisticated AD recon paired with detailed, customized, & actionable recommendations.
- Trimarc only requires AD user rights
- Includes in-depth review of AD & GPO permissions
- Identification of custom privileged AD groups with rights defined outside of group membership
- Review of auditing & security settings configured via GPO
- Domain Controller configuration review (agent discovery)
- AD Administration review
- Engagement is 4 to 6 Weeks (depending on scope & scale)

Announcing:
Trimarc Active Directory Security Review (ADSR)

- Lighter version of our Active Directory Security Assessment for small, single domain forests.
- Review is focused on the most common AD security issues
- Engagement timeline is 2 weeks
- Doesn’t required corporate network access
- PowerShell script provided to export key AD data
- Performed completely offline; no corporate network access required
- Initially for non-profits and Mergers & Acquisitions (M&A) scenarios
- Launching Fall 2020

Securing Active Directory: Performing Your Own AD Security Review



Sean Metcalf (@Pyrotek3)
s e a n [@] TrimarcSecurity.com
www.ADSecurity.org
TrimarcSecurity.com
@TrimarcSecurity

About

- Founder Trimarc (Trimarc.io), a professional services company that helps organizations better secure their Microsoft platform, including the Microsoft Cloud.
- Microsoft Certified Master (MCM) Directory Services
- Microsoft MVP
- Speaker: Black Hat, Blue Hat, Bsides DC, BSides Charm, BSides PR, DEF CON, DerbyCon
- Security Consultant / Researcher
- AD Enthusiast - Own & Operate ADSecurity.org (Microsoft platform security info)



Agenda

- Identifying AD Security Issues
  - User Account Issues
  - Domain Password Policy
  - Tombstone Lifetime & Backups
  - Trusts
  - Duplicate SPNs
  - Group Policy Preference Passwords
  - AD Administration & Privileged Accounts
  - KRBTGT
  - Kerberos Delegation
  - Domain & GPO Permissions
  - Domain Controller Security
- Putting It all Together
- AD Security Scan Tools
- Conclusion
- Q & A



Enforce MFA on all Privileged Azure AD/Office 365 Accounts

(for @markmorrow ☺)



~~Enforce MFA on all privileged Azure AD/Office 365 accounts~~

Enforce Privileged Identity Management control of all Azure AD Roles

(for @markmorrow ☺)



Identifying AD Security Issues

Sean Metcalf (@PyroTek3) | TrimarcSecurity.com



User Account Issues

- Inactive accounts (combination of Password Age & User Logon Age)
- Reversible Encryption
- Password Not Required
- Password Never Expires
- DES Kerberos Encryption Enabled
- Do not require Kerberos Pre-Authentication
- SID History



```powershell
## Get Domain User Information
$LastLoggedOnDate = $(Get-Date) - $(New-TimeSpan -days $UserLogonAge)
$PasswordStaleDate = $(Get-Date) - $(New-TimeSpan -days $UserPasswordAge)
$ADLimitedProperties = @("Name","Enabled","SAMAccountname","DisplayName","Enabled","LastLogonDate","PasswordLastSet","P

[array]$DomainUsers = Get-ADUser -Filter * -Property $ADLimitedProperties -Server $DomainDC
[array]$DomainEnabledUsers = $DomainUsers | Where {$_.Enabled -eq $True }
[array]$DomainEnabledInactiveUsers = $DomainEnabledUsers | Where { ($_.LastLogonDate -le $LastLoggedOnDate) -AND `
  ($_.PasswordLastSet -le $PasswordStaleDate) }

[array]$DomainUsersWithReversibleEncryptionPasswordArray = $DomainUsers | Where { $_.UserAccountControl -band 0x0080 }
[array]$DomainUserPasswordNotRequiredArray = $DomainUsers | Where {$_.PasswordNotRequired -eq $True}
[array]$DomainUserPasswordNeverExpiresArray = $DomainUsers | Where {$_.PasswordNeverExpires -eq $True}
[array]$DomainKerberosDESUsersArray = $DomainUsers | Where { $_.UserAccountControl -band 0x200000 }
[array]$DomainUserDoesNotRequirePreAuthArray = $DomainUsers | Where {$_.DoesNotRequirePreAuth -eq $True}
[array]$DomainUsersWithSIDHistoryArray = $DomainUsers | Where {$_.SIDHistory -like "*"}

Write-Output " "
$DomainUserReport =
@"
$Domain Domain User Report:

Total Users: $($DomainUsers.Count)
Enabled Users: $($DomainEnabledUsers.Count)

Enabled Users Identified as Inactive: $($DomainEnabledInactiveUsers.Count)
Enabled Users With Reversible Encryption Password: $($DomainUsersWithReversibleEncryptionPasswordArray.Count)
Enabled Users With Password Not Required: $($DomainUserPasswordNotRequiredArray.Count)
Enabled Users With Password Never Expires: $($DomainUserPasswordNeverExpiresArray.Count)
Enabled Users With Kerberos DES: $($DomainKerberosDESUsersArray.Count)
Enabled Users That Do Not Require Kerberos Pre-Authentication: $($DomainUserDoesNotRequirePreAuthArray.Count)
Enabled Users With SID History: $($DomainUsersWithSIDHistoryArray.Count)

Review & clean up as appropriate

"@
$DomainUserReport
```

User Account Issues

```
lab.trimarcresearch.com Domain User Report:

Total Users: 284
Enabled Users: 85

Enabled Users Identified as Inactive: 75
Enabled Users With Reversible Encryption Password: 3
Enabled Users With Password Not Required: 2
Enabled Users With Password Never Expires: 33
Enabled Users With Kerberos DES: 4
Enabled Users That Do Not Require Kerberos Pre-Authentication: 0
Enabled Users With SID History: 0

Review & clean up as appropriate
```

Domain Password Policy

- Policy determines how passwords are created and when.
- Domain Password Policy should be set to 12 characters or more.
- Increasing password length can limit Password Spray effectiveness.
- Fine-Grained Password Policies (FGPP) provide flexibility.

```
Get-ADPasswordPolicy
```

```
Domain Password Policy for Lab.trimarcresearch.com


MinPasswordLength            : 3
ComplexityEnabled            : True
ReversibleEncryptionEnabled : False
MaxPasswordAge               : 42.00:00:00
MinPasswordAge               : 1.00:00:00
PasswordHistoryCount         : 24
```

Tombstone Lifetime & Backups

- Tombstone Lifetime
  - Effectively determines how long DC backups are valid
  - Old default 60 days
  - Now 180 days
  - Set to 180 days (or more if needed)
- System State Backups are required to properly backup AD.
- Can check last supported AD backup date.
- Events like “Install From Media” creation on a DC can update AD backup date.



Tombstone Lifetime & Backups

```powershell
## Tombstone Lifetime & AD Backups
$ADRootDSE = get-adrootdse
$ADConfigurationNamingContext = $ADRootDSE.configurationNamingContext
$ForestRootDN = $ADRootDSE.rootDomainNamingContext
$ForestNCs = $ADRootDSE.NamingContexts
$DomainControllerSiteNameDN = "CN=Sites,$ADConfigurationNamingContext"
$TombstoneObjectInfo = Get-ADObject -Identity "CN=Directory Service,CN=Windows NT,CN=Services,$ADConfigurationNamingContext" `
-Partition "$ADConfigurationNamingContext" -Properties *
[int]$TombstoneLifetime = $TombstoneObjectInfo.tombstoneLifetime
IF ($TombstoneLifetime -eq 0) { $TombstoneLifetime = 60 }
Write-Host "The AD Forest Tombstone lifetime is set to $TombstoneLifetime days." -Fore Cyan

## AD Backups
# From https://devblogs.microsoft.com/scripting/use-a-powershell-script-to-show-active-directory-backup-status-info/
[string[]]$Partitions = (Get-ADRootDSE).namingContexts
$contextType = [System.DirectoryServices.ActiveDirectory.DirectoryContextType]::Domain
$context = new-object System.DirectoryServices.ActiveDirectory.DirectoryContext($contextType,$ADDomainName)
$domainController = [System.DirectoryServices.ActiveDirectory.DomainController]::findOne($context)
Write-Host "Determining last supported backup of AD partitions... `n" -ForegroundColor Cyan
ForEach($partition in $partitions)
{
    $domainControllerMetadata = $domainController.GetReplicationMetadata($partition)
    $dsaSignature = $domainControllerMetadata.Item("dsaSignature")
    Write-Host "$partition was backed up $($dsaSignature.LastOriginatingChangeTime.DateTime)"
}
```

```
The AD Forest Tombstone lifetime is set to 30 days.

Determining last supported backup of AD partitions...
CN=Configuration,DC=trimarcresearch,DC=com was backed up Wednesday, May 6, 2020 8:44:21 PM
CN=Schema,CN=Configuration,DC=trimarcresearch,DC=com was backed up Wednesday, May 6, 2020 8:44:21 PM
DC=ForestDnsZones,DC=trimarcresearch,DC=com was backed up Wednesday, May 6, 2020 8:44:21 PM
DC=Lab,DC=trimarcresearch,DC=com was backed up Wednesday, May 6, 2020 8:44:21 PM
DC=DomainDnsZones,DC=Lab,DC=trimarcresearch,DC=com was backed up Wednesday, May 6, 2020 8:44:21 PM
```

Trusts

- Review trust configuration & ensure that trusts are appropriate.
- Bidirectional trusts should be reviewed to determine if required.
- Trusts with DMZ environments should be removed (if possible).
- If a trust is required, look to shift to Selective Authentication which changes from Allow All to only those explicitly allowed to connect across the trust.

Selective Authentication:
https://www.microsoftpressstore.com/articles/article.aspx?p=2199426&seqNum=3



Trusts

```
## Trusts
$ADTrusts = Get-ADTrust -Filter * -Server $DomainDC
$ADTrustFile = $ReportDir + "\TrimarcADChecks-DomainTrustReport-$Domain-$TimeVal.csv"
$ADTrusts | Export-CSV $ADTrustFile -NoTypeInformation
Write-Host "$Domain Active Directory Trusts: `n" -Fore Cyan
$ADTrusts | Select Source,Target,Direction,IntraForest,SelectiveAuth,SIDFilteringForestAware,SIDFilteringQuarantined `
| Format-Table -AutoSize
Write-Host "Active Directory Trusts ($Domain) saved to the file $ADTrustFile `n"
```

```
lab.trimarcresearch.com Active Directory Trusts:



Source                      : DC=Lab,DC=trimarcresearch,DC=com
Target                      : trimarcresearch.com
Direction                   : BiDirectional
IntraForest                 : True
SelectiveAuth               : {}
SIDFilteringForestAware     : False
SIDFilteringQuarantined     : False
```

Active Directory Duplicate SPNs

- When there are duplicate SPNs, Kerberos authentication breaks
- Fallback auth = NTLM
- Krbtgt config is normal

```
PS C:\> SetSPN -X -F | where {$_ -notlike "Processing entry*"}
Checking forest DC=trimarcresearch,DC=com
Operation will be performed forestwide, it might take a while.

MSSQLSvc/EchoDB11:1433 is registered on these accounts:
    CN=Alpha35_svc,OU=Service Accounts,DC=Prod,DC=trimarcresearch,DC=com
    CN=Alpha42_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com

kadmin/changepw is registered on these accounts:
    CN=krbtgt,CN=Users,DC=Dev,DC=trimarcresearch,DC=com
    CN=krbtgt,CN=Users,DC=Prod,DC=trimarcresearch,DC=com
    CN=krbtgt,CN=Users,DC=trimarcresearch,DC=com
    CN=krbtgt,CN=Users,DC=Lab,DC=trimarcresearch,DC=com

found 2 groups of duplicate SPNs.
```




Group Policy Preference Passwords

- Group Policy Preferences can manage account credentials.
- Don’t do this. Microsoft has blocked new credentials from being added to GPP – old ones are still there.
- GPP capability with credentials:
  - Map drives (Drives.xml)
  - Create Local Users
  - Data Sources (DataSources.xml)
  - Printer configuration (Printers.xml)
  - Create/Update Services (Services.xml)
  - Scheduled Tasks (ScheduledTasks.xml)
  - Change local Administrator passwords




```
PS C:\temp> (findstr /S /I cpassword $DomainSYSVOLShareScan ) -Split ':'
\\lab.trimarcresearch.com\SYSVOL\lab.trimarcresearch.com\Policies\{BC5325A39-9710-4B1F-93A5-AF754E97AC1A}\groups.xml
cpassword="3462erwehgwryhwrtgq9eihurt89`34ht89qhergiudhfgqhsdufgbqsoduiqhret89hqr89hqrht"
```

https://adsecurity.org/?p=2288

AD Admin Account Checks

```
Get-ADGroupMember Administrators -Recursive
```

- Passwords change regularly (every year)
- Disable inactive accounts
- Remove disabled accounts
- No SPNs on accounts associated with people
- No computer accounts
- Scrutinize Service Accounts
  - What do they do?
  - Where do they run?
  - What computers do they authenticate to?
  - What rights are actually required?



AD Admins

```powershell
## Identify AD Admins
$ADAdminArray = @()
$ADAdminMembers = Get-ADGroupMember Administrators -Recursive
ForEach ($ADAdminMemberItem in $ADAdminMembers)
 {
  Switch ($ADAdminMemberItem.objectClass)
   {
    'User' { [array]$ADAdminArray += Get-ADUser $ADAdminMemberItem -Properties LastLogonDate,PasswordLastSet,ServicePrincipalName }
    'Computer' { [array]$ADAdminArray += Get-ADComputer $ADAdminMemberItem -Properties LastLogonDate,PasswordLastSet }
    'msDS-GroupManagedServiceAccount' { [array]$ADAdminArray += Get-ADServiceAccount $ADAdminMemberItem -Properties LastLogonDate,PasswordLastSet }
   }
 }
Write-Host " "
Write-Host "$ADDomainName AD Admins: " -Fore Cyan
$ADAdminArray | sort PasswordLastSet | select name,DistinguishedName,PasswordLastSet,LastLogonDate,ObjectClass | Format-Table -AutoSize
```

```
Lab.trimarcresearch.com AD Admins:

name          DistinguishedName                                                          PasswordLastSet       LastLogonDate        ObjectClass
----          -----------------                                                          ---------------       -------------        -----------
SVC-LAB-GMSA1 CN=SVC-LAB-GMSA1,CN=Managed Service Accounts,DC=Lab,DC=trimarcresearch,DC=com 6/10/2020 8:15:07 AM   6/2/2020 3:06:11 AM  msDS-GroupManagedServiceAccount
Administrator CN=Administrator,CN=Users,DC=Lab,DC=trimarcresearch,DC=com                  5/19/2020 4:32:44 PM   5/11/2020 1:16:56 PM user
VMWareAdmin   CN=VMWareAdmin,OU=Service Accounts,DC=trimarcresearch,DC=com                11/10/2019 11:57:14 PM                      user
Administrator CN=Administrator,CN=Users,DC=trimarcresearch,DC=com                         2/11/2020 2:08:55 PM   6/9/2020 8:12:05 PM  user
SharepointSVC CN=SharepointSVC,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com       11/13/2019 9:18:33 AM                       user
admEGray      CN=admEGray,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com 11/10/2019 11:27:06 PM                 user
admMBailey    CN=admMBailey,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com 11/10/2019 11:26:46 PM              user
```

AD Admin Accounts Not Member of Protected Users

- All AD Admin accounts should be added to the “Protected Users” group
- Protected Users group provides additional protections.
  - Kerberos AES authentication only (No Kerberos DSE/RC4 or NTLM)
  - No Kerberos delegation (constrained or unconstrained)
  - Kerberos TGT set to 4 hours
  - Credential delegation (CredSSP) will not cache the user's plain text credentials
  - NTLM will not cache the user's plain text credentials or NT one-way function
  - Offline sign-in is not supported

```
Lab.trimarcresearch.com AD Admins:

name
----
SVC-LAB-GMSA1
Administrator
VMWareAdmin
Administrator
SharepointSVC
admEGray
admMBailey

Lab.trimarcresearch.com Domain Protected Users Group Membership:

name        DistinguishedName                                                                  objectClass
----        -----------------                                                                  -----------
admAGreen   CN=admAGreen,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com   user
admBCollins CN=admBCollins,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com user
admALong    CN=admALong,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com    user
admAButler  CN=admAButler,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com  user
admGMoore   CN=admGMoore,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com   user
admNEvans   CN=admNEvans,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com   user
admDSimmons CN=admDSimmons,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com user
```

AD Admins with Old Passwords

- Ensure privileged account passwords change annually.
- Older passwords are typically poor and easier to guess.
- Password Spraying & Kerberoasting are popular attack methods for compromising accounts lacking strong passwords.

```
Lab.trimarcresearch.com AD Admins:

name          DistinguishedName                                                                PasswordLastSet
----          -----------------                                                                ---------------
admMBailey    CN=admMBailey,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com 11/10/2019 11:26:46 PM
admEGray      CN=admEGray,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com   11/10/2019 11:27:06 PM
VMWareAdmin   CN=VMWareAdmin,OU=Service Accounts,DC=trimarcresearch,DC=com                     11/10/2019 11:57:14 PM
SharepointSVC CN=SharepointSVC,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com            11/13/2019 9:18:33 AM
Administrator CN=Administrator,CN=Users,DC=trimarcresearch,DC=com                              2/11/2020 2:08:55 PM
Administrator CN=Administrator,CN=Users,DC=Lab,DC=trimarcresearch,DC=com                       5/19/2020 4:32:44 PM
SVC-LAB-GMSA1 CN=SVC-LAB-GMSA1,CN=Managed Service Accounts,DC=Lab,DC=trimarcresearch,DC=com    6/10/2020 8:15:07
```

AD Admin Accounts: Old Passwords

SamAccountName	Enabled	PasswordLastSet	Password Age (years)
Administrator	**Yes**	**1/9/2005 10:58:24 AM**	**15**
AGPMService	**Yes**	**5/3/2009 3:17:32 PM**	**10.8**
SCCMsvc	**Yes**	**11/14/2011 5:23:12 PM**	**8.6**
VMWareAdmin	**Yes**	**8/28/2012 10:23:41 AM**	**7.5**
admAEdwards	**Yes**	**1/12/2013 2:20:06 PM**	**7.0**
VulnerabilityScanner	**Yes**	**9/19/2015 4:43:19 PM**	**4.5**
admBWalker	No	6/11/2017 10:14:08 AM	2.8
admCGriffin	Yes	3/1/2019 12:41:18 PM	1.0



AD Admins with SPNs

- Attackers can “kerberoast” accounts with Kerberos Service Principal Names (SPNs).
- Kerberoast:
  - 1. Request Kerberos service ticket for SPN (RC4 encrypted which uses the NT password hash for the ticket encryption key).
  - 2. Move the service ticket to a password cracking system and perform hybrid password guessing
  - 3. Guess the password correctly and the service ticket opens.

```
Lab.trimarcresearch.com AD Admin Accounts with SPNs:

name          DistinguishedName                                                ServicePrincipalName
----          -----------------                                                --------------------
Administrator CN=Administrator,CN=Users,DC=Lab,DC=trimarcresearch,DC=com       {MSSQLSvc/GammaDB23:1434, MSSQLSvc/Ga
SharepointSVC CN=SharepointSVC,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com {http/TRDSharePoint02, http/TRDShareP
admEGray      CN=admEGray,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com {gateway/gatewayAPP47}
```

Check Default Domain Administrator Account for Issues

- Account Enabled?
- Password changed recently?
- Account has a SPN?
- Account should be reserved as an emergency account (aka "break glass)

```
lab.trimarcresearch.com Default Domain Administrator Account:


Name          Enabled Created              PasswordLastSet      LastLogonDate        ServicePrincipalName
----          ------- -------              ---------------      -------------        --------------------
Administrator    True 11/10/2019 3:36:51 PM 5/19/2020 4:32:44 PM 5/11/2020 1:16:56 PM {MSSQLSvc/GammaDB23:1434, MSSQLSvc/GammaDB14:14
```

Review AD Default/Built-In Group Membership

```
## Privileged AD Group Array
$ADPrivGroupArray = @(
  'Administrators',
  'Domain Admins',
  'Enterprise Admins',
  'Schema Admins',
  'Account Operators',
  'Server Operators',
  'Group Policy Creator Owners',
  'DNSAdmins',
  'Enterprise Key Admins',
  # Exchange Privileged Groups
  'Exchange Domain Servers',
  'Exchange Enterprise Servers',
  'Exchange Admins',
  'Organization Management',
  'Exchange Windows Permissions'
)
```

Review AD Default/Built-In Group Membership

```
## Discover Default privileged group membership
ForEach ($ADPrivGroupItem in $ADPrivGroupArray)
 {
    $ADPrivGroupItemGroupMembership = @()
    TRY
     {
        $ADPrivGroupItemGroupMembership = Get-ADGroupMember $ADPrivGroupItem -Server $DomainDC
        IF ($ADPrivGroupItemGroupMembership.count -ge 1)
         {
            Write-Host "$ADDomainName Domain $ADPrivGroupItem Group:" -Fore Cyan
            $ADPrivGroupItemGroupMembership | Select name,DistinguishedName,objectClass | Format-Table

            $ADPrivGroupItemGroupMembershipFile = $ReportDir + "\TrimarcADChecks-PrivGroups-$Domain-$ADPrivGroupItem-$TimeVal.cs
            $ADPrivGroupItemGroupMembership | Export-CSV $ADPrivGroupItemGroupMembershipFile -NoTypeInformation
         }
        ELSE
         { Write-Host "$ADDomainName Domain $ADPrivGroupItem Group:  No members" -Fore Cyan }
     }
    CATCH
     { Write-Warning "An error occured when attempting to enumerate group membership for the group $ADPrivGroupItem `
     in the domain $Domain using the DC $DomainDC" }

    Write-Host ""
 }
```

Default AD Groups: Administrators

- Active Directory admin rights (for the domain)
- Domain Controller admin rights (for the domain)

```
Lab.trimarcresearch.com Domain Administrators Group:

name               DistinguishedName                                                                objectClass
----               -----------------                                                                -----------
SVC-LAB-GMSA1      CN=SVC-LAB-GMSA1,CN=Managed Service Accounts,DC=Lab,DC=trimarcresearch,DC=com    msDS-GroupManagedServiceAccount
Server Admins - DCs CN=Server Admins - DCs,OU=Admin Groups,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com group
Enterprise Admins  CN=Enterprise Admins,CN=Users,DC=trimarcresearch,DC=com                           group
Domain Admins      CN=Domain Admins,CN=Users,DC=Lab,DC=trimarcresearch,DC=com                        group
Administrator      CN=Administrator,CN=Users,DC=Lab,DC=trimarcresearch,DC=com                        user
```

Default AD Groups: Domain Admins

- Membership in the domain Administrators group which provides most rights.
- Active Directory admin rights (for the domain)
- Domain Controller admin rights (for the domain)
- Default rights on all domain Group Policies
- Default local Administrator on all domain-joined computers

```
Lab.trimarcresearch.com Domain Domain Admins Group:

name          DistinguishedName                                                    objectClass
----          -----------------                                                    -----------
Administrator CN=Administrator,CN=Users,DC=Lab,DC=trimarcresearch,DC=com           user
admMBailey    CN=admMBailey,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com user
admEGray      CN=admEGray,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com   user
SharepointSVC CN=SharepointSVC,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com user
admCMorgan    CN=admCMorgan,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com user
```



Default AD Groups: Enterprise Admins

- Membership in every domain Administrators group which provides most rights.
- Active Directory admin rights (in every forest domain)
- Domain Controller admin rights (in every forest domain)
- Default rights on all domain Group Policies
- This group should remain empty in a single domain forest and membership very limited in a multi-domain forest.

```
trimarcresearch.com Domain Enterprise Admins Group:

name          DistinguishedName                                          objectClass
----          -----------------                                          -----------
VMWareAdmin   CN=VMWareAdmin,OU=Service Accounts,DC=trimarcresearch,DC=com user
Administrator CN=Administrator,CN=Users,DC=trimarcresearch,DC=com         user
```

Default AD Groups: Schema Admins

- This group only exists in the forest root domain.
- Only group that is able to modify the AD schema (forest-wide).
- This group should remain empty until the schema needs updating

```
trimarcresearch.com Domain Schema Admins Group:

name          DistinguishedName                                          objectClass
----          -----------------                                          -----------
SCCM          CN=SCCM,OU=Service Accounts,DC=trimarcresearch,DC=com      user
Administrator CN=Administrator,CN=Users,DC=trimarcresearch,DC=com         user
```

Default AD Groups: Server Operators

- Default rights on Domain Controllers:
  - Log on locally
  - create and delete shared resources
  - start and stop some services
  - backup and restore files
  - format the hard disk
  - shut down the computer
- This group has no default members.
- This group is effectively “Domain Controller Admins” and members of this group should be scrutinized at a similar level to Domain Admins.

```
Lab.trimarcresearch.com Domain Server Operators Group:

name              DistinguishedName                                                                  objectClass
----              -----------------                                                                  -----------
Tyrone Johnson    CN=Tyrone Johnson,OU=Users,OU=WashingtonDC,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com   user
Keshia Washington CN=Keshia Washington,OU=Users,OU=NewYorkCity,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com user
SVC-LAB-GMSA1     CN=SVC-LAB-GMSA1,CN=Managed Service Accounts,DC=Lab,DC=trimarcresearch,DC=com                msDS-GroupManagedServiceAccount
admCJohnson       CN=admCJohnson,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com            user
```

Default AD Groups: Account Operators

- Has rights to most objects in the domain (users, groups, computers, etc).
- This group has no default members.
- This group should remain empty

> ⓘ Note
>
> By default, this built-in group has no members, and it can create and manage users and groups in the domain, including its own membership and that of the Server Operators group. This group is considered a service administrator group because it can modify Server Operators, which in turn can modify domain controller settings. As a best practice, leave the membership of this group empty, and do not use it for any delegated administration. This group cannot be renamed, deleted, or moved.

Privileged Group: VMWare Admins

- We see this in most environments:
  VMWare Admins AD group with full VMWare Admin rights
- Ensure that VMWare Admins follow privileged account best practices:
  - Use separate admin accounts
  - Use admin workstations
  - Passwords change about once a year

```
Lab.trimarcresearch.com Domain CN=VMWare Admins,OU=Admin Groups,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com Group:

name            DistinguishedName                                                                  objectClass
----            -----------------                                                                  -----------
admEGray        CN=admEGray,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com    user
Isabel Gonzalez CN=Isabel Gonzalez,OU=Users,OU=Bogota,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com  user
Jose Rodriquez  CN=Jose Rodriquez,OU=Users,OU=BuenosAires,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com  user
Crystal Kennedy CN=Crystal Kennedy,OU=Users,OU=WashingtonDC,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com user
Ebony Smith     CN=Ebony Smith,OU=Users,OU=Dallas,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com  user
```

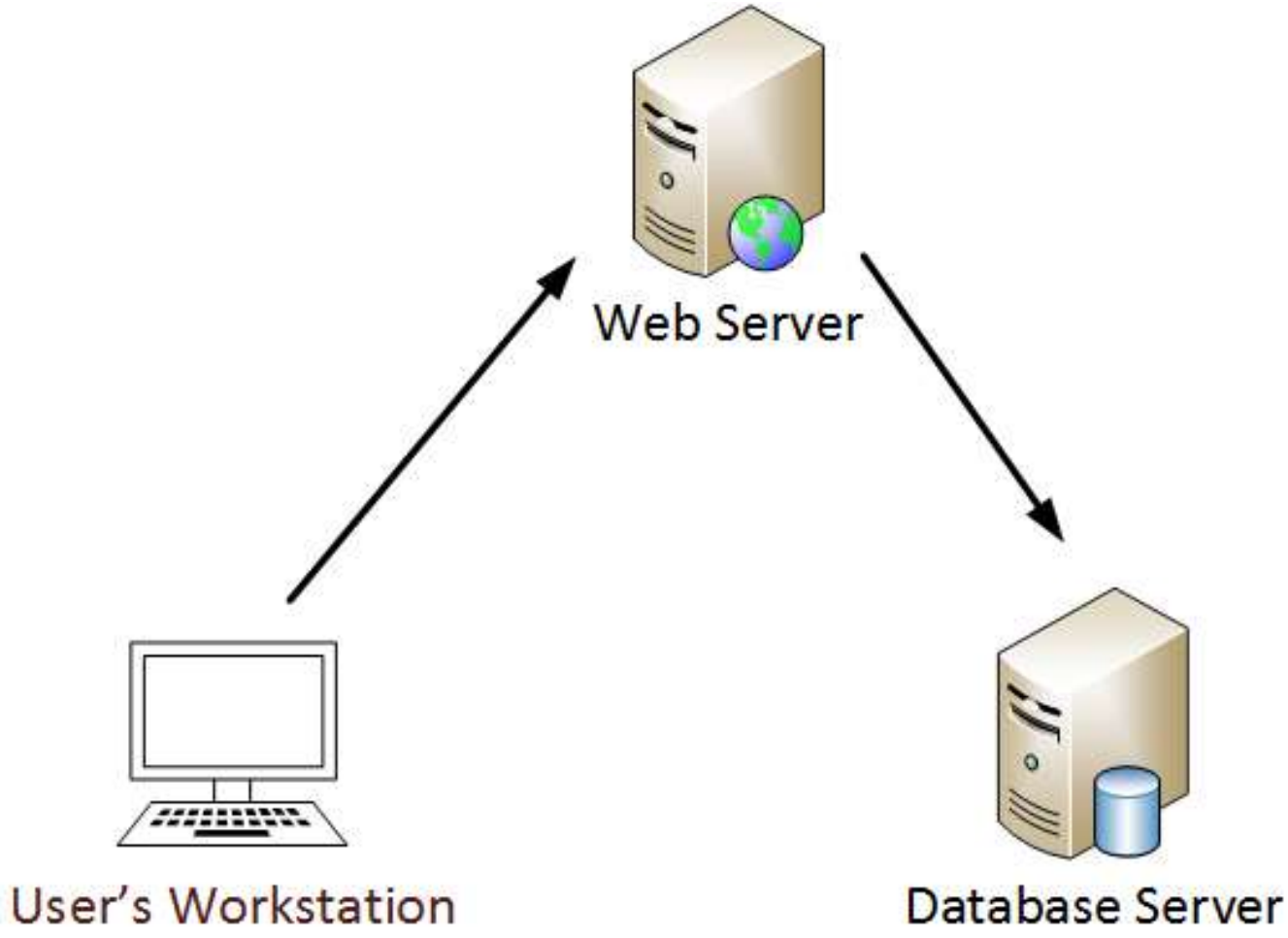
Krbtgt Password Not Changed Recently

- KRBTGT account is disabled but used for Kerberos Tickets.
- Password set when created & practically never changes.
- DC/AD backups contains KRBTGT pw.
- If an attacker gains knowledge of pw, Golden Tickets!!!
- Change this password 2x every year (DoD STIG requirement)
- Change after AD admins leave

```
lab.trimarcresearch.com Domain Kerberos Service Account (KRBTGT):

DistinguishedName                                    Created              PasswordLastSet      msds-keyversionnumber
-----------------                                    -------              ---------------      ---------------------
CN=krbtgt,CN=Users,DC=Lab,DC=trimarcresearch,DC=com 11/10/2019 3:37:59 PM 11/10/2019 3:37:59 PM                     2
```

Kerberos "Double Hop" Issue



Kerberos Delegation

- **Unconstrained:**
  Impersonate users connecting to service to ANY Kerberos service.
- **Constrained:**
  Impersonate authenticated users connecting to service to SPECIFIC Kerberos services on servers.
- **Constrained with Protocol Transition:**
  Impersonate any user to SPECIFIC Kerberos services on servers. (aka "Kerberos Magic")
- **Resource-based Constrained Delegation:**
  Enables delegation configured on the resource instead of the account.

Kerberos Delegation Recommendations

- Set all AD Admin accounts to:
  "Account is sensitive and cannot be delegated"
- Add all AD Admin accounts to the "Protected Users" group (Windows 2012 R2 DCs).
- Ensure service accounts with Kerberos delegation have long, complex passwords (preferably group Managed Service Accounts).
- Remove delegation from accounts that don't require it.
- Don't use Domain Controller SPNs when delegating.
- Work to shift accounts with unconstrained delegation to constrained.
- Restrict & monitor who has the ability to configure Kerberos delegation.



Kerberos Delegation

```powershell
## Identify Accounts with Kerberos Delegation
$KerberosDelegationArray = @()
[array]$KerberosDelegationObjects =  Get-ADObject -filter { ( (UserAccountControl -BAND 0x0080000) -OR (UserAccountControl -BAND 0x1000000) -OR `
   (msDS-AllowedToDelegateTo -like '*') -OR (msDS-AllowedToActOnBehalfOfOtherIdentity -like '*')) -AND (PrimaryGroupID -ne '516') -AND `
    (PrimaryGroupID -ne '521') } -Server $DomainDC -prop Name,ObjectClass,PrimaryGroupID,UserAccountControl,ServicePrincipalName, `
     msDS-AllowedToDelegateTo,msDS-AllowedToActOnBehalfOfOtherIdentity -SearchBase $DOmainDN

ForEach ($KerberosDelegationObjectItem in $KerberosDelegationObjects)
 {
    IF ($KerberosDelegationObjectItem.UserAccountControl -BAND 0x0080000)
     { $KerberosDelegationServices = 'All Services' ; $KerberosType = 'Unconstrained' }
    ELSE
     { $KerberosDelegationServices = 'Specific Services' ; $KerberosType = 'Constrained' }

    IF ($KerberosDelegationObjectItem.UserAccountControl -BAND 0x1000000)
     { $KerberosDelegationAllowedProtocols = 'Any (Protocol Transition)' ; $KerberosType = 'Constrained with Protocol Transition' }
    ELSE
     { $KerberosDelegationAllowedProtocols = 'Kerberos' }

    IF ($KerberosDelegationObjectItem.'msDS-AllowedToActOnBehalfOfOtherIdentity')
     { $KerberosType = 'Resource-Based Constrained Delegation'  }

    $KerberosDelegationObjectItem | Add-Member -MemberType NoteProperty -Name Domain -Value $Domain -Force
    $KerberosDelegationObjectItem | Add-Member -MemberType NoteProperty -Name KerberosDelegationServices -Value $KerberosDelegationServices -Force
    $KerberosDelegationObjectItem | Add-Member -MemberType NoteProperty -Name DelegationType -Value $KerberosType -Force
    $KerberosDelegationObjectItem | Add-Member -MemberType NoteProperty -Name KerberosDelegationAllowedProtocols -Value $KerberosDelegationAllowedProtocols -Force

    [array]$KerberosDelegationArray += $KerberosDelegationObjectItem
 }

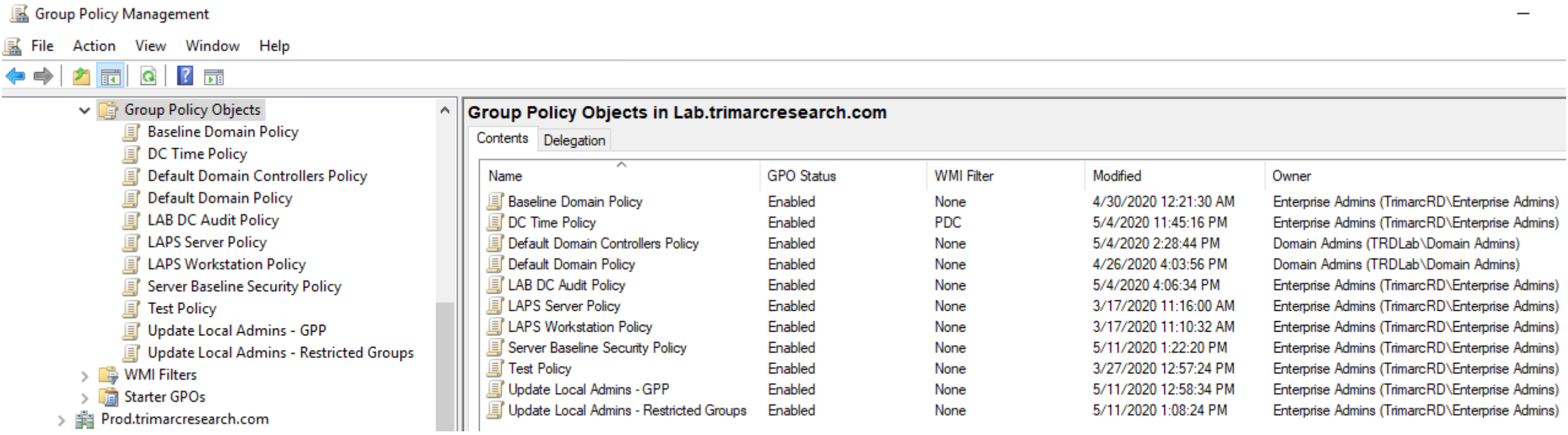
Write-Host ""
Write-Host "$Domain Domain Accounts with Kerberos Delegation:" -Fore Cyan
$KerberosDelegationArray | Sort DelegationType | Select DistinguishedName,DelegationType,Name,ServicePrincipalName | Format-Table -AutoSize
Write-Host ""
$KerberosDelegationReportFile = $ReportDir + "\TrimarcADChecks-KerberosDelegationReport-$Domain-$TimeVal.csv"
$KerberosDelegationArray | Sort DelegationType | Export-CSV $KerberosDelegationReportFile -NoTypeInformation
```

Kerberos Delegation

```
lab.trimarcresearch.com Domain Accounts with Kerberos Delegation:

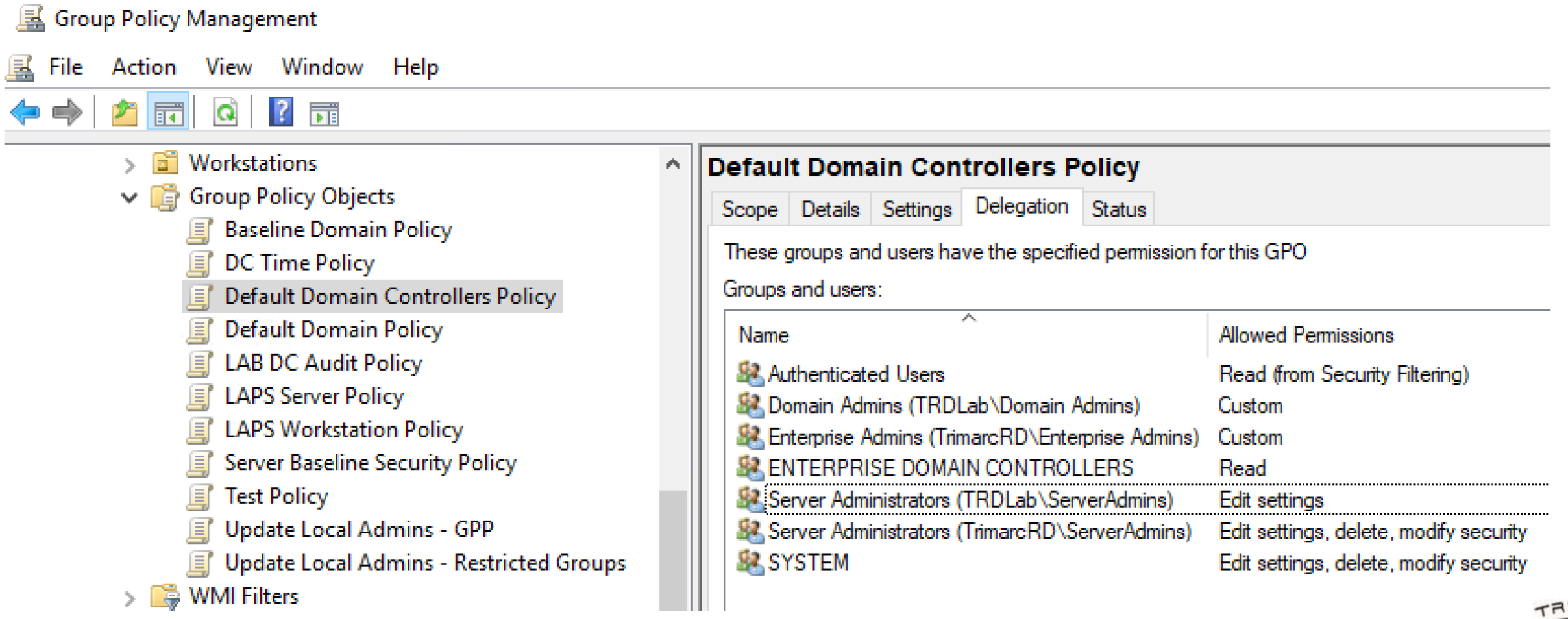
DistinguishedName                                                                DelegationType                                 Name          ServicePrincipalName
-----------------                                                                --------------                                 ----          --------------------
CN=Delta38_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Constrained                                    Delta38_svc   {MSSQLSvc/DeltaDB4:1433,
CN=Echo36_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained                                    Echo36_svc    {MSSQLSvc/EchoDB35:5555}
CN=Alpha22_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Constrained                                    Alpha22_svc   {MSSQLSvc/AlphaDB11:1433,
CN=Gamma16_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Constrained with Protocol Transition           Gamma16_svc   {MSSQLSvc/GammaDB37:Gamma
CN=Gamma40_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Constrained with Protocol Transition           Gamma40_svc   {MSSQLSvc/GammaDB23:Gamma
CN=Delta35_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Constrained with Protocol Transition           Delta35_svc   {MSSQLSvc/DeltaDB35:Delta
CN=Beta29_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained with Protocol Transition           Beta29_svc    {MSSQLSvc/BetaDB45:Beta}
CN=Delta26_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Constrained with Protocol Transition           Delta26_svc   {MSSQLSvc/DeltaDB13:Delta
CN=Echo20_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained with Protocol Transition           Echo20_svc    {MSSQLSvc/EchoDB27:Echo}
CN=Echo28_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained with Protocol Transition           Echo28_svc    {}
CN=Alpha41_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Constrained with Protocol Transition           Alpha41_svc   {MSSQLSvc/AlphaDB32:5555,
CN=Echo37_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained with Protocol Transition           Echo37_svc    {MSSQLSvc/EchoDB30:Echo}
CN=Beta39_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained with Protocol Transition           Beta39_svc    {MSSQLSvc/BetaDB7:3341}
CN=Beta48_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained with Protocol Transition           Beta48_svc    {MSSQLSvc/BetaDB6:3341}
CN=Beta20_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained with Protocol Transition           Beta20_svc    {MSSQLSvc/BetaDB44:3341}
CN=Beta23_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained with Protocol Transition           Beta23_svc    {MSSQLSvc/BetaDB33:Beta}
CN=Echo27_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained with Protocol Transition           Echo27_svc    {MSSQLSvc/EchoDB11:Echo}
CN=Delta11_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Constrained with Protocol Transition           Delta11_svc   {MSSQLSvc/DeltaDB20:Delta
CN=Beta37_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained with Protocol Transition           Beta37_svc    {}
CN=Alpha35_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Constrained with Protocol Transition           Alpha35_svc   {MSSQLSvc/AlphaDB39:Alpha
CN=Gamma44_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Constrained with Protocol Transition           Gamma44_svc   {MSSQLSvc/GammaDB8:Gamma}
CN=Beta1_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com                Constrained with Protocol Transition           Beta1_svc     {MSSQLSvc/BetaDB26:3341}
CN=Gamma29_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Constrained with Protocol Transition           Gamma29_svc   {MSSQLSvc/GammaDB40:5555}
CN=Echo15_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained with Protocol Transition           Echo15_svc    {MSSQLSvc/EchoDB35:1433}
CN=Beta12_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Constrained with Protocol Transition           Beta12_svc    {MSSQLSvc/BetaDB39:1433}
CN=SVC-LAB-GMSA1,CN=Managed Service Accounts,DC=Lab,DC=trimarcresearch,DC=com    Resource-Based Constrained Delegation          SVC-LAB-GMSA1 {MSSQLSvc/LCNSQL01.lab.tr
CN=GammaDB8,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                          Resource-Based Constrained Delegation          GammaDB8      {}
CN=Echo2_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com                Unconstrained                                  Echo2_svc     {MSSQLSvc/EchoDB13:Echo}
CN=Beta33_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Unconstrained                                  Beta33_svc    {MSSQLSvc/BetaDB15:Beta}
CN=Delta29_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Unconstrained                                  Delta29_svc   {MSSQLSvc/DeltaDB40:Delta
CN=Beta6_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com                Unconstrained                                  Beta6_svc     {}
CN=Beta17_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Unconstrained                                  Beta17_svc    {MSSQLSvc/BetaDB46:Beta}
CN=Alpha5_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Unconstrained                                  Alpha5_svc    {MSSQLSvc/AlphaDB30:1433}
CN=Delta39_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Unconstrained                                  Delta39_svc   {MSSQLSvc/DeltaDB1:3341}
CN=Echo48_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com               Unconstrained                                  Echo48_svc    {MSSQLSvc/EchoDB23:Echo}
CN=Alpha31_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Unconstrained                                  Alpha31_svc   {MSSQLSvc/AlphaDB17:1433}
CN=Alpha26_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com              Unconstrained                                  Alpha26_svc   {MSSQLSvc/AlphaDB41:3341}
```

GPO Permissions: Review Owners



Name	GPO Status	WMI Filter	Modified	Owner
Baseline Domain Policy	Enabled	None	4/30/2020 12:21:30 AM	Enterprise Admins (TrimarcRD\Enterprise Admins)
DC Time Policy	Enabled	PDC	5/4/2020 11:45:16 PM	Enterprise Admins (TrimarcRD\Enterprise Admins)
Default Domain Controllers Policy	Enabled	None	5/4/2020 2:28:44 PM	Domain Admins (TRDLab\Domain Admins)
Default Domain Policy	Enabled	None	4/26/2020 4:03:56 PM	Domain Admins (TRDLab\Domain Admins)
LAB DC Audit Policy	Enabled	None	5/4/2020 4:06:34 PM	Enterprise Admins (TrimarcRD\Enterprise Admins)
LAPS Server Policy	Enabled	None	3/17/2020 11:16:00 AM	Enterprise Admins (TrimarcRD\Enterprise Admins)
LAPS Workstation Policy	Enabled	None	3/17/2020 11:10:32 AM	Enterprise Admins (TrimarcRD\Enterprise Admins)
Server Baseline Security Policy	Enabled	None	5/11/2020 1:22:20 PM	Enterprise Admins (TrimarcRD\Enterprise Admins)
Test Policy	Enabled	None	3/27/2020 12:57:24 PM	Enterprise Admins (TrimarcRD\Enterprise Admins)
Update Local Admins - GPP	Enabled	None	5/11/2020 12:58:34 PM	Enterprise Admins (TrimarcRD\Enterprise Admins)
Update Local Admins - Restricted Groups	Enabled	None	5/11/2020 1:08:24 PM	Enterprise Admins (TrimarcRD\Enterprise Admins)

GPO Permissions: Review GPO Delegation



Review Domain Permissions

```powershell
## Get Domain Permissions
Write-Output "Gathering Domain Permissions for $Domain"
$ForestDomainObjectData = Get-ADObject $ADDomainInfo.DistinguishedName -Properties *
$ForestDomainObjectSecurityData = $ForestDomainObjectData.nTSecurityDescriptor.Access
$ForestDomainObjectPermissions = @()
ForEach ($ForestDomainObjectSecurityDataItem in $ForestDomainObjectSecurityData)
 {
    $ObjectTypeName = Get-NameForGUID $ForestDomainObjectSecurityDataItem.ObjectType
    $InheritedObjectTypeName = Get-NameForGUID $ForestDomainObjectSecurityDataItem.InheritedObjectType

    $ForestDomainObjectSecurityDataItem | Add-Member -MemberType NoteProperty -Name Domain -Value $Domain -Force
    $ForestDomainObjectSecurityDataItem | Add-Member -MemberType NoteProperty -Name ObjectTypeName -Value $ObjectTypeName -Force
    $ForestDomainObjectSecurityDataItem | Add-Member -MemberType NoteProperty -Name InheritedObjectTypeName -Value $InheritedObjectTypeName -Force

    [array]$ForestDomainObjectPermissions += $ForestDomainObjectSecurityDataItem
 }
$ForestDomainObjectPermissionFile = $ReportDir + "\TrimarcADChecks-DomainRootPermissionReport-$Domain-$TimeVal.csv"
$ForestDomainObjectPermissions | Sort IdentityReference | Select IdentityReference,ActiveDirectoryRights,InheritedObjectTypeName,ObjectTypeName,`
InheritanceType,ObjectFlags,AccessControlType,IsInherited,InheritanceFlags,PropagationFlags,ObjectType,InheritedObjectType | `
Export-CSV $ForestDomainObjectPermissionFile -NoTypeInformation
```




Review Domain Permissions

IdentityReference	ActiveDirectoryRights	InheritedObjectTypeNam	ObjectTypeName	AccessControlTy
S-1-5-21-1362129023-2533104153-2294267348-527	ReadProperty, WriteProperty	All	msDS-KeyCredentialLink	Allow
TRDLab\AADC_Svc	ExtendedRight	All	DS-Replication-Get-Changes	Allow
TRDLab\AADC_Svc	ExtendedRight	All	DS-Replication-Get-Changes-All	Allow
TRDLab\AADC_Svc	ReadProperty, WriteProperty, GenericExecute	All	All	Allow
TRDLab\Cloneable Domain Controllers	ExtendedRight	All	DS-Clone-Domain-Controller	Allow
TRDLab\Domain Computers	GenericAll	All	All	Allow
TRDLab\Key Admins	ReadProperty, WriteProperty	All	msDS-KeyCredentialLink	Allow
TRDLab\MSOL_trd326848506	ReadProperty, WriteProperty, GenericExecute	All	All	Allow
TRDLab\MSOL_trd326848506	ExtendedRight	All	DS-Replication-Get-Changes	Allow
TRDLab\MSOL_trd326848506	ExtendedRight	All	DS-Replication-Get-Changes-All	Allow
TRDLab\SharepointSVC	ReadProperty, WriteProperty, GenericExecute	All	All	Allow
TRDLab\SharepointSVC	ExtendedRight	All	DS-Replication-Get-Changes	Allow
TrimarcRD\Enterprise Admins	GenericAll	All	All	Allow
TrimarcRD\Enterprise Read-only Domain Controllers	ExtendedRight	All	DS-Replication-Get-Changes	Allow
TrimarcRD\Incoming Forest Trust Builders	ExtendedRight	All	Create-Inbound-Forest-Trust	Allow



Improper Domain Permissions

IdentityReference	ActiveDirectoryRights	InheritedObjectTypeNam	ObjectTypeName
S-1-5-21-1362129023-2533104153-2294267348-527	ReadProperty, WriteProperty	All	msDS-KeyCredentialLink
TRDLab\AADC_Svc	ExtendedRight	All	DS-Replication-Get-Changes
TRDLab\AADC_Svc	ExtendedRight	All	DS-Replication-Get-Changes-All
TRDLab\AADC_Svc	ReadProperty, WriteProperty, GenericExecute	All	All
TRDLab\Cloneable Domain Controllers	ExtendedRight	All	DS-Clone-Domain-Controller
TRDLab\Domain Computers	GenericAll	All	All
TRDLab\Key Admins	ReadProperty, WriteProperty	All	msDS-KeyCredentialLink
TRDLab\MSOL_trd326848506	ReadProperty, WriteProperty, GenericExecute	All	All
TRDLab\MSOL_trd326848506	ExtendedRight	All	DS-Replication-Get-Changes
TRDLab\MSOL_trd326848506	ExtendedRight	All	DS-Replication-Get-Changes-All

IdentityReference	ActiveDirectoryRights	InheritedObjectTypeNam	ObjectTypeName	Acc
S-1-5-21-1362129023-2533104153-2294267348-527	ReadProperty, WriteProperty	All	msDS-KeyCredentialLink	All
TRDLab\AADC_Svc	ExtendedRight	All	DS-Replication-Get-Changes	All
TRDLab\AADC_Svc	ExtendedRight	All	DS-Replication-Get-Changes-All	All
TRDLab\AADC_Svc	ReadProperty, WriteProperty, GenericExecute	All	All	All
TRDLab\Cloneable Domain Controllers	ExtendedRight	All	DS-Clone-Domain-Controller	All
TRDLab\Domain Computers	GenericAll	All	All	All

DC OS & Functional Level Security Improvements

- Windows Server 2008 R2
  - AD Recycle Bin
  - Last interactive logon information
  - Fine-grained password policies
  - Authentication mechanism assurance which identifies logon method type (smart card or user name/password)
  - Managed Service Accounts (let AD handle the password)
  - Automatic SPN management for services running under context of a Managed Service Account.
  - Goodbye Kerberos DES, hello AES
- Windows Server 2012/2012 R2
  - Focus on protecting credentials
  - Shift in security focus
  - DC-side protections for Protected Users
    - No NTLM authentication
    - No Kerberos DES or RC4 ciphers
    - No Delegation – unconstrained or constrained delegation
    - No user tickets (TGTs) renewed beyond the initial 4 hr lifetime
  - Authentication Policies & Authentication Policy Silos
- Windows Server 2016
  - New shadow security principals (groups)
  - An expiring links feature (Group TTL)
  - KDC enhancements to restrict Kerberos ticket lifetime to the lowest group TTL

Domain Controllers Running Old Versions

- DCs must be running Microsoft supported Windows versions
- You can run all Windows Server 2012 R2 DCs even with older Windows Server versions in the domain*
- All DCs should be running a minimum of Windows Server 2012 R2, preferably 2016/2019
- If all DCs are not running 2012 R2 with 2012R2 DFL, Protected Users group doesn't have full domain protection.



Domain Controllers Running Old Versions

```
## Get Domain Controllers
$DomainDCs = Get-ADDomainController -filter *
Write-Host "$ADDomainName AD Forest Domain Controllers and OS Version:  `n" -Fore Cyan
$DomainDCs | Select HostName,OperatingSystem | Format-Table -AutoSize
```

```
Lab.trimarcresearch.com AD Forest Domain Controllers and OS Version:


HostName                              OperatingSystem
--------                              ---------------
TRDC11.Lab.trimarcresearch.com Windows Server 2019 Datacenter
```

AD FFL/DFL Older than DC OS (& 2012)

- Forest & Domain Functional Levels have less emphasis in recent versions.
- All AD Forests should match the DC version (after all DCs in the AD forest are running the same version).



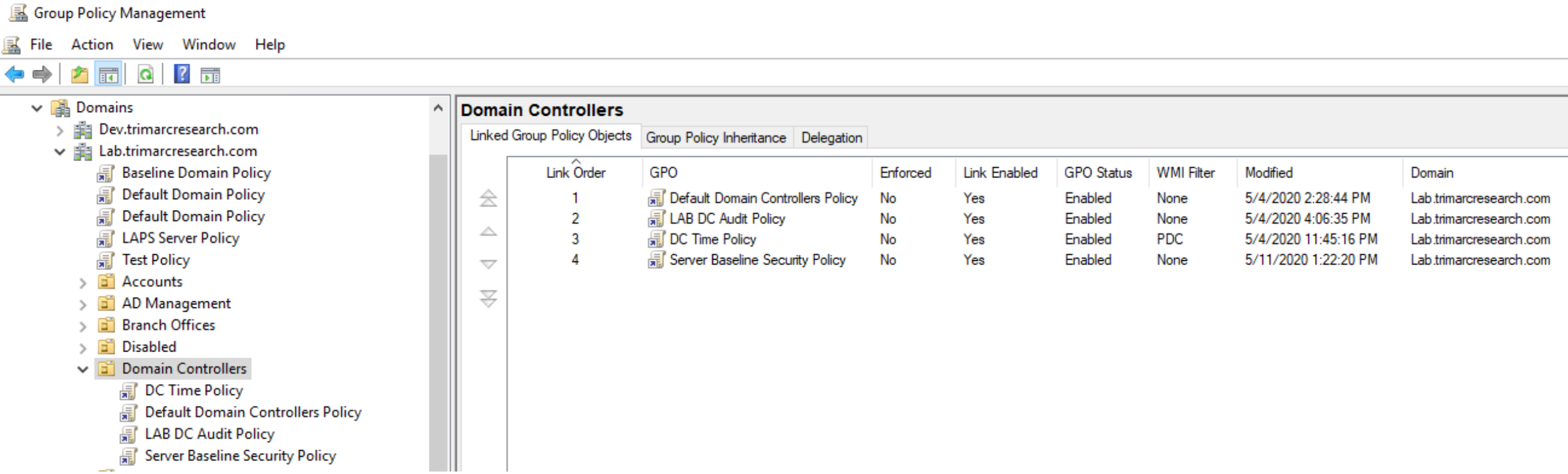
AD FFL/DFL Older than DC OS (& 2012)

```
## Identify AD FFL/DFL
## Get AD Forest & Domain Info
$ADFFL = (Get-ADForest).ForestMode
$ADDFL = (Get-ADDomain $Domain).DomainMode
Write-Host "The AD Forest Functional Level is $ADFFL `n" -Fore Cyan
Write-Host "The AD Domain Functional Level ($Domain) is $ADFFL `n" -Fore Cyan
```

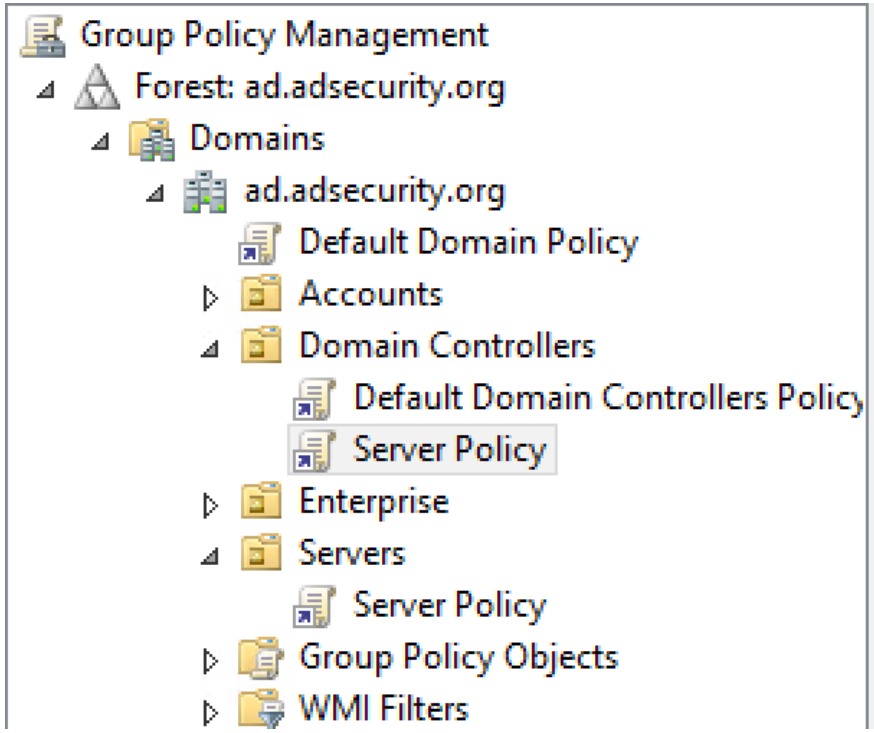
```
The AD Forest Functional Level is Windows2008Forest

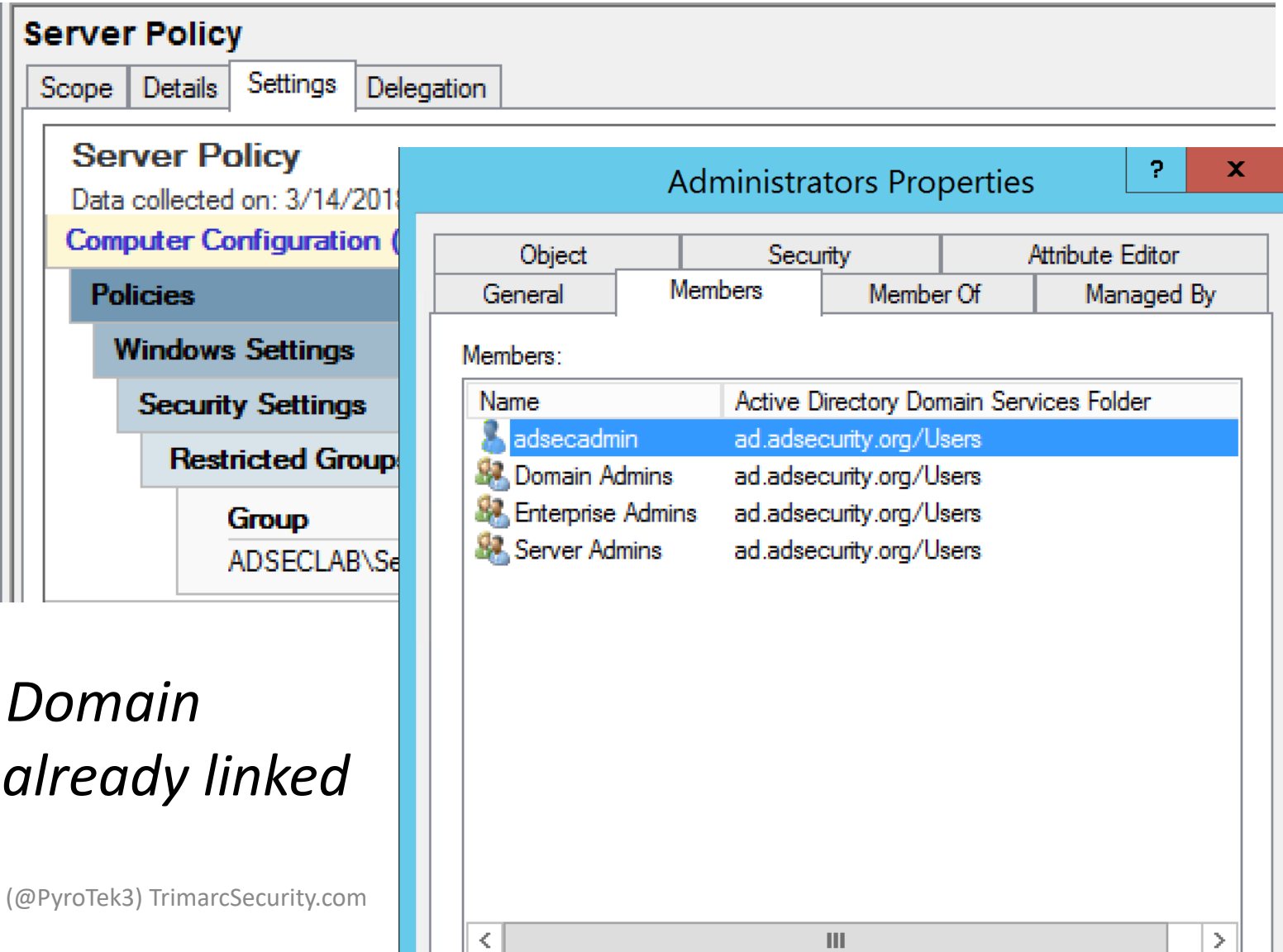
The AD Domain Functional Level (lab.trimarcresearch.com) is Windows2008Forest
```

Domain Controller GPO Configuration



Server GPOs Linked to Domain Controllers





Only use GPOs dedicated to Domain Controllers, don't link GPOs already linked to other OUs.

Domain Controller Advanced Audit Policy



LAB DC Audit Policy

Scope | Details | Settings | Delegation

Name	Allowed Permissions	Inherited
NT AUTHORITY\Authenticated Users	Read (from Security Filtering)	No
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS	Read	No
NT AUTHORITY\SYSTEM	Edit settings, delete, modify security	No
TRDLab\Domain Admins	Edit settings, delete, modify security	No
TrimarcRD\Enterprise Admins	Edit settings, delete, modify security	No

Computer Configuration (Enabled) hide

Policies hide

Windows Settings hide

Security Settings hide

Local Policies/Audit Policy hide

Policy	Setting
Audit account logon events	Success
Audit account management	Success
Audit logon events	Success
Audit privilege use	Success, Failure

Advanced Audit Configuration hide

Account Logon hide

Policy	Setting
Audit Credential Validation	Success, Failure

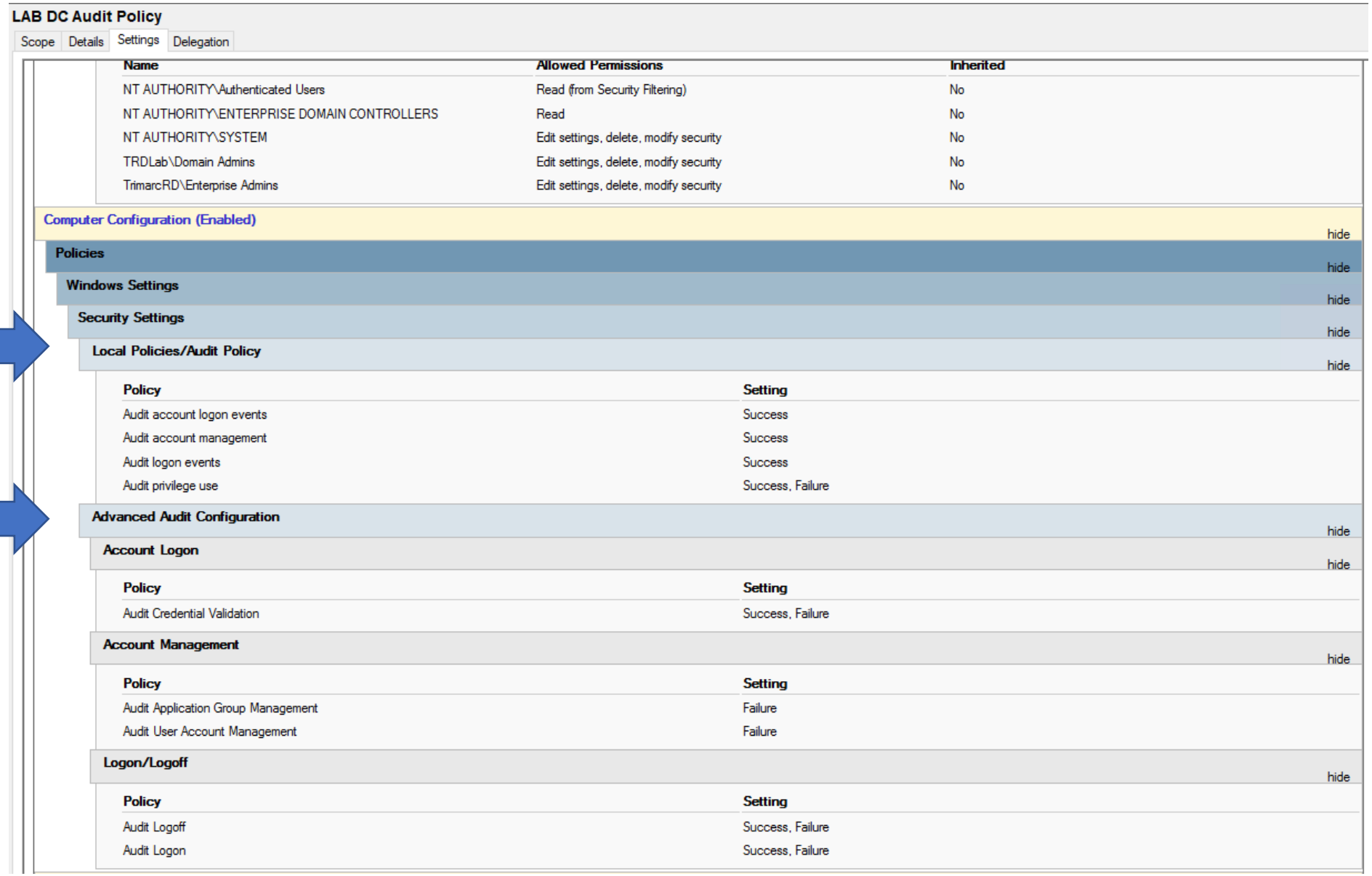
Account Management hide

Policy	Setting
Audit Application Group Management	Failure
Audit User Account Management	Failure

Logon/Logoff hide

Policy	Setting
Audit Logoff	Success, Failure
Audit Logon	Success, Failure

Domain Controller Advanced Audit Policy



LAB DC Audit Policy

Scope | Details | Settings | Delegation

Name	Allowed Permissions	Inherited
NT AUTHORITY\Authenticated Users	Read (from Security Filtering)	No
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS	Read	No
NT AUTHORITY\SYSTEM	Edit settings, delete, modify security	No
TRDLab\Domain Admins	Edit settings, delete, modify security	No
TrimarcRD\Enterprise Admins	Edit settings, delete, modify security	No

Computer Configuration (Enabled) hide

Policies hide

Windows Settings hide

Security Settings hide

Local Policies/Audit Policy hide

Policy	Setting
Audit account logon events	Success
Audit account management	Success
Audit logon events	Success
Audit privilege use	Success, Failure

Advanced Audit Configuration hide

Account Logon hide

Policy	Setting
Audit Credential Validation	Success, Failure

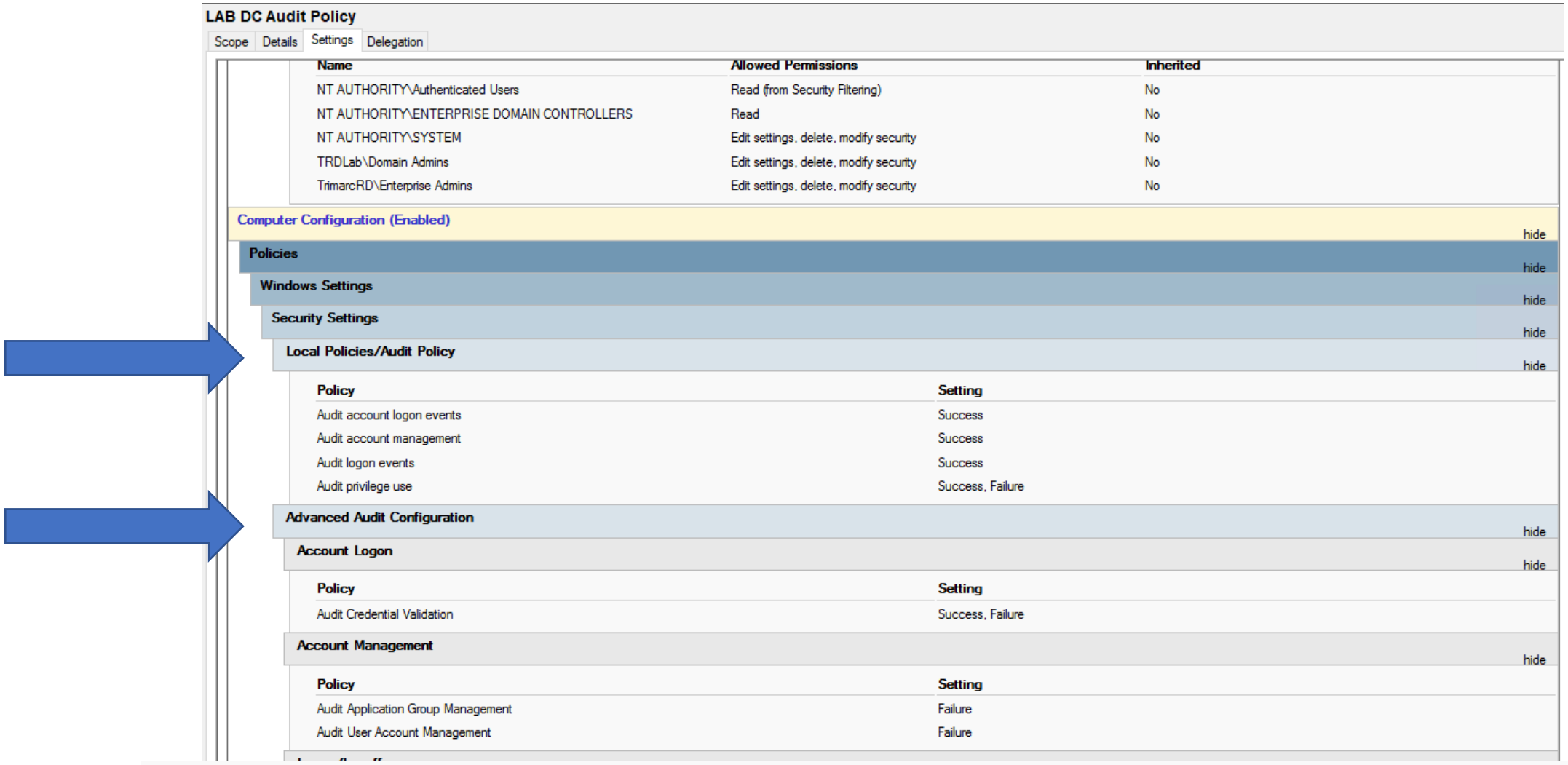
Account Management hide

Policy	Setting
Audit Application Group Management	Failure
Audit User Account Management	Failure

Logon/Logoff hide

Policy	Setting
Audit Logoff	Success, Failure
Audit Logon	Success, Failure

Domain Controller Advanced Audit Policy



Policy	Setting
Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings	Enabled

Review Domain Controller User Rights Assignment

- Add workstations to domain
- Allow log on locally
- Allow log through Terminal Services
- Debug programs
- Enable computer and user accounts to be trusted for delegation
- Load and unload device drivers
- Manage auditing and security log
- Take ownership of files or other objects

Domain Controller User Rights Assignment

Default Domain Controllers Policy

Scope | Details | Settings | Delegation

Local Policies/User Rights Assignment hide

Policy	Setting
Access this computer from the network	BUILTIN\Pre-Windows 2000 Compatible Access, NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS, NT AUTHORITY\Authenticated Users, BUILTIN\Administrators, Everyone
Act as part of the operating system	TrimarcRD\TRD Domain Controller Administrators
Add workstations to domain	NT AUTHORITY\Authenticated Users
Adjust memory quotas for a process	BUILTIN\Administrators, NT AUTHORITY\NETWORK SERVICE, NT AUTHORITY\LOCAL SERVICE
Allow log on locally	BUILTIN\Account Operators, BUILTIN\Administrators, BUILTIN\Backup Operators, NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS, BUILTIN\Print Operators, BUILTIN\Server Operators, TrimarcRD\Enterprise Admins, TrimarcRD\TRD Domain Controller Administrators
Allow log on through Terminal Services	BUILTIN\Administrators, TrimarcRD\TRD Domain Controller Administrators
Back up files and directories	BUILTIN\Server Operators, BUILTIN\Backup Operators, BUILTIN\Administrators
Bypass traverse checking	BUILTIN\Pre-Windows 2000 Compatible Access, NT AUTHORITY\Authenticated Users, BUILTIN\Administrators, NT AUTHORITY\NETWORK SERVICE, NT AUTHORITY\LOCAL SERVICE, Everyone
Change the system time	BUILTIN\Server Operators, BUILTIN\Administrators, NT AUTHORITY\LOCAL SERVICE
Create a pagefile	BUILTIN\Administrators
Debug programs	TrimarcRD\TRD Domain Controller Administrators, TRDDEV\ServerAdmins, BUILTIN\Administrators
Enable computer and user accounts to be trusted for delegation	BUILTIN\Administrators
Force shutdown from a remote system	BUILTIN\Administrators, BUILTIN\Server Operators, TRDLab\LAB Domain Controller Admins
Generate security audits	NT AUTHORITY\NETWORK SERVICE, NT AUTHORITY\LOCAL SERVICE
Increase scheduling priority	Window Manager\Window Manager Group, BUILTIN\Administrators
Load and unload device drivers	BUILTIN\Print Operators, BUILTIN\Administrators
Log on as a batch job	BUILTIN\Performance Log Users, BUILTIN\Backup Operators, BUILTIN\Administrators
Manage auditing and security log	TRDLab\LAB Domain Controller Admins, TRDDEV\ServerAdmins, BUILTIN\Administrators
Modify firmware environment values	BUILTIN\Administrators
Profile single process	BUILTIN\Administrators
Profile system performance	NT SERVICE\WdiServiceHost, BUILTIN\Administrators
Remove computer from docking station	BUILTIN\Administrators
Replace a process level token	NT AUTHORITY\NETWORK SERVICE, NT AUTHORITY\LOCAL SERVICE
Restore files and directories	BUILTIN\Server Operators, BUILTIN\Backup Operators, BUILTIN\Administrators
Shut down the system	TRDDEV\LAPSAdmins, BUILTIN\Server Operators, BUILTIN\Print Operators, enterprise admins, BUILTIN\Backup Operators, BUILTIN\Administrators
Take ownership of files or other objects	BUILTIN\Administrators



Review Domain Controller User Rights Assignment

- Add workstations to domain
  - Only AD Admins & specific groups/accounts should have this right
- Allow log on locally & Allow log through Terminal Services
  - Only AD Admins should have this right
- Debug programs
  - Not required
- Enable computer and user accounts to be trusted for delegation (Kerberos)
  - Only AD Admins should have this right
- Load and unload device drivers (can compromise DC)
  - Not required
- Manage auditing and security log (can clear security logs)
  - AD Admins & Exchange groups only
- Take ownership of files or other objects (become owner of AD objects)
  - Only AD Admins should have this right

Tools for Reviewing AD

Sean Metcalf (@PyroTek3) | TrimarcSecurity.com



Ping Castle



Get Active Directory Security at 80% in 20% of the time

Active directory is quickly becoming a critical failure point in any big sized company, as it is both complex and costly to secure..

https://www.pingcastle.com/

ADCollector

https://hakin9.org/adcollector-a-lightweight-tool-to-quickly-extract-valuable-information-from-the-active-directory-environment-for-both-attacking-and-defending/

ADCollector

ADCollector is a lightweight tool that enumerates the Active Directory environment to identify possible attack vectors. It will give you a basic understanding of the configuration/deployment of the environment as a starting point.

Notes:

ADCollector is not an alternative to the powerful PowerView, it just automates enumeration to quickly identify juicy information without thinking too much at the early Recon stage. Functions implemented in ADCollector are ideal for enumeration in a large Enterprise environment with lots of users/computers, without generating lots of traffic and taking a large amount of time. It only focuses on extracting useful attributes/properties/ACLs from the most valuable targets instead of enumerating all available attributes from all the user/computer objects in the domain. You will definitely need PowerView to do more detailed enumeration later.

The aim of developing this tool is to help me learn more about Active Directory security in a different perspective as well as to figure out what's behind the scenes of those PowerView functions. I just started learning .NET with C#, the code could be really **terrible**~~

It uses S.DS namespace to retrieve domain/forest information from the domain controller(LDAP server). It also utilizes S.DS.P namespace for LDAP searching.

This tool is still under construction. Features will be implemented can be seen from my project page

Enumeration

- Current Domain/Forest information
- Domains in the current forest (with domain SIDs)
- Domain Controllers in the current domain [GC/RODC] (with ~~IP,OS Site and ~~Roles)
- Domain/Forest trusts as well as trusted domain objects(SID filtering status)
- Privileged users (currently in DA and EA group)
- Unconstrained delegation accounts (Excluding DCs)
- Constrained Delegation (S4U2Self, S4U2Proxy, Resources-based constrained delegation)
- MSSQL/Exchange/RDP/PS Remoting SPN accounts
- User accounts with SPN set & password does not expire account
- Confidential attributes ()
- ASREQROAST (DontRequirePreAuth accounts)
- AdminSDHolder protected accounts
- Domain attributes (MAQ, minPwdLength, maxPwdAge lockoutThreshold, gpLink(group policies that linked to the current domain object))
- LDAP basic info(supportedLDAPVersion, supportedSASLMechanisms, domain/forest/DC Functionality)
- Kerberos Policy
- Interesting ACLs on the domain object, resolving GUIDs (User defined object in the future)
- Unusual DCSync Accounts
- Interesting ACLs on GPOs
- Interesting descriptions on user objects
- Sensitive & Not delegate account
- Group Policy Preference cpassword in SYSVOL/Cache
- Effective GPOs on the current user/computer
- Restricted groups
- Nested Group Membership

ADRecon

https://github.com/sense-of-security/ADRecon

ADRecon: Active Directory Recon

Follow @ad_recon 245

ADRecon is a tool which extracts and combines various artefacts (as highlighted below) out of an AD environment. The information can be presented in a specially formatted Microsoft Excel report that includes summary views with metrics to facilitate analysis and provide a holistic picture of the current state of the target AD environment.

The tool is useful to various classes of security professionals like auditors, DFIR, students, administrators, etc. It can also be an invaluable post-exploitation tool for a penetration tester.

It can be run from any workstation that is connected to the environment, even hosts that are not domain members. Furthermore, the tool can be executed in the context of a non-privileged (i.e. standard domain user) account. Fine Grained Password Policy, LAPS and BitLocker may require Privileged user accounts. The tool will use Microsoft Remote Server Administration Tools (RSAT) if available, otherwise it will communicate with the Domain Controller using LDAP.

The following information is gathered by the tool:

- Forest;
- Domain;
- Trusts;
- Sites;
- Subnets;
- Default and Fine Grained Password Policy (if implemented);
- Domain Controllers, SMB versions, whether SMB Signing is supported and FSMO roles;
- Users and their attributes;
- Service Principal Names (SPNs);
- Groups and memberships;
- Organizational Units (OUs);
- GroupPolicy objects and gPLink details;
- DNS Zones and Records;
- Printers;
- Computers and their attributes;
- PasswordAttributes (Experimental);
- LAPS passwords (if implemented);
- BitLocker Recovery Keys (if implemented);
- ACLs (DACLs and SACLs) for the Domain, OUs, Root Containers, GPO, Users, Computers and Groups objects;
- GPOReport (requires RSAT);
- Kerberoast (not included in the default collection method); and
- Domain accounts used for service accounts (requires privileged account and not included in the default collectio

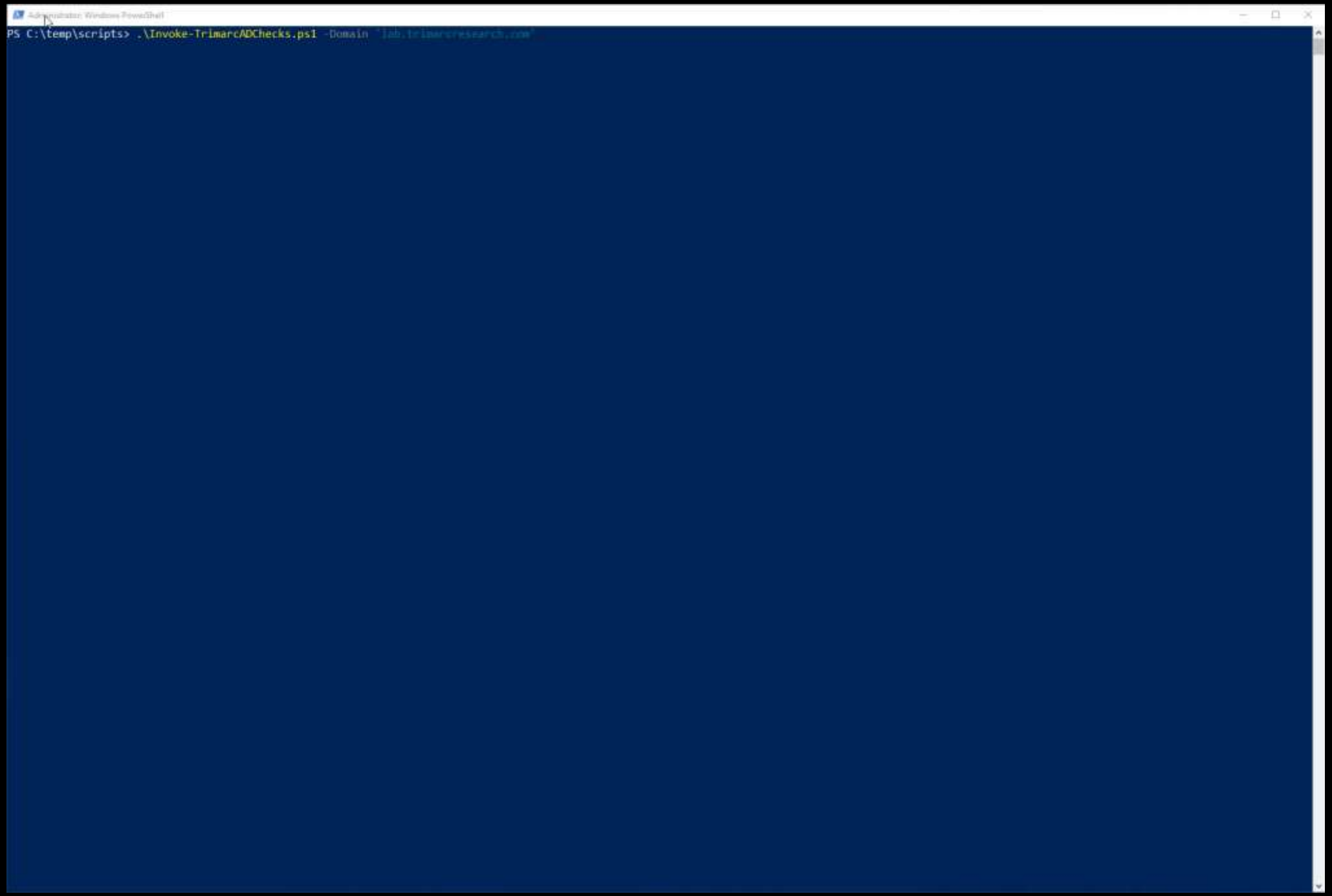
TRIMARC

Invoke-TrimarcADChecks (PowerShell)

- Trimarc developed based on our Active Directory Security Assessment (ADSA) engagement focus.
- Gathers data for key AD security items in a domain:
  - User Account Issues
  - Domain Password Policy
  - Tombstone Lifetime & AD Backup Dates
  - Trusts
  - Duplicate SPNs
  - Group Policy Preference Passwords
  - AD Administration & Privileged Accounts
  - KRBTGT Account
  - Kerberos Delegation

DEMO: Invoke-TrimarcADChecks.ps1




Administrator: Windows PowerShell
PS C:\temp\scripts> .\Invoke-TrimarcADChecks.ps1 -Domain "lab.trimarcresearch.com"

Conclusion



- You can check many key AD security areas.
- Active Directory security requires review of:
  - User Account Issues
  - Domain Password Policy
  - Tombstone Lifetime & Backups
  - Trusts
  - Duplicate SPNs
  - Group Policy Preference Passwords
  - AD Administration & Privileged Accounts
  - KRBTGT
  - Kerberos Delegation
  - Domain & GPO Permissions
  - Domain Controller Security

Slides & Video:
Trimarc.co/SecurityWebcasts

Sean Metcalf (@Pyrotek3)
s e a n @ Trimarc Security .com
www.ADSecurity.org
TrimarcSecurity.com

Upcoming Trimarc Webcasts



Securing Active Directory: Protecting AD Administration
Wednesday, July 15, 2020
1pm to 2pm (Eastern)
Presenter: Sean Metcalf

Registration: Trimarc.co/SecurityWebcasts